```
const express=require('express'),
{Pool}=require('pg'),crypto=require('crypto'),fs=require('fs');
const app=express(),URL=process.env.DATABASE_URL||'',db=new
Pool({connectionString:URL,options:'-c
search_path=vendas,public',max:1,ssl:/localhost|127\.0\.0\.1/.test(URL)?false:
{rejectUnauthorized:false}});
const SECRET=process.env.SESSION_SECRET||'troque-este-segredo',MATRIZ='Gerente da
matriz',ROLES=['Analista comercial','Gerente de filial',MATRIZ],COLL=
['sales','reqs','cobs','config'];
app.use(express.json({limit:'1mb'}));
app.use((q,s,n)=>ready.then(()=>n(),e=>
{console.error(e);s.status(500).json({erro:'Banco indisponível.'})}));
const sign=v=>crypto.createHmac('sha256',SECRET).update(v).digest('hex');
const hash=
(p,s=crypto.randomBytes(16).toString('hex'))=>s+':'+crypto.scryptSync(p,s,64).toStrin
g('hex');
const check=(p,h)=>
{const[s,k]=h.split(':'),a=Buffer.from(k,'hex'),b=crypto.scryptSync(p,s,64);return
a.length===b.length&&crypto.timingSafeEqual(a,b)};
const cookie=(req,res,v,age)=>res.setHeader('Set-Cookie',`s=${v}; HttpOnly;
SameSite=Lax; Path=/; Max-Age=${age}${req.headers['x-forwarded-proto']==='https'?';
Secure':''}`);
function login(req,res,uid){const v=uid+'.'+
(Date.now()+30*864e5);cookie(req,res,v+'.'+sign(v),30*86400)}
async function auth(req,res,next){try{const m=/(?:^|; )s=
([^;]+)/.exec(req.headers.cookie||'');if(m){const
p=m[1].split('.');if(p.length===3&&sign(p[0]+'.'+p[1])===p[2]&&+p[1]>Date.now())
{const r=await db.query('select id,email,nome,tel,mat,fi,role from users where
id=$1',[p[0]]);if(r.rows[0]){req.u=r.rows[0];return
next()}}}res.status(401).json({erro:'Entre para continuar.'})}catch(e)
{console.error(e);res.status(500).json({erro:'Erro no servidor.'})}}
const isM=u=>u.role===MATRIZ,fil=f=>String(f||'').trim().toLowerCase();
const S="select id from docs where coll='sales' and lower(trim(data->>'fi'))=";
function scope(u,c,k){if(isM(u)||c==='config')return'';if(c==='sales')return` and
lower(trim(data->>'fi'))=${k}`;if(c==='reqs')return` and data->>'sid' in
(${S}${k})`;return` and data->>'rid' in (select id from docs where coll='reqs' and
data->>'sid' in (${S}${k}))`}
const bad=(res,code,erro)=>res.status(code).json({erro});
app.post('/api/register',async(req,res)=>{try{const b=req.body||
{},nome=String(b.nome||'').trim(),email=String(b.email||'').trim().toLowerCase(),tel=
String(b.tel||'').trim(),senha=String(b.senha||'');let fi=String(b.fi||'').trim();
if(nome.length<5||!nome.includes(' '))return bad(res,400,'Informe o nome completo.');
if(!/^[^@\s]+@[^@\s]+\.[^@\s]+$/.test(email))return bad(res,400,'E-mail inválido.');
if(tel.replace(/\D/g,'').length<10)return bad(res,400,'Informe o telefone com DDD.');
if(senha.length<6)return bad(res,400,'A senha precisa ter ao menos 6 caracteres.');
if(!ROLES.includes(b.role))return bad(res,400,'Escolha uma função.');
```

```
if(b.role===MATRIZ)
{if(!process.env.MATRIZ_CODE||b.codigo!==process.env.MATRIZ_CODE)return
bad(res,403,'Código da matriz incorreto.');fi='Recife/PE'}
if(!fi)return bad(res,400,'Informe a filial.');
const r=await db.query('insert into users(email,hash,nome,tel,mat,fi,role)
values($1,$2,$3,$4,$5,$6,$7) on conflict do nothing returning id',
[email,hash(senha),nome,tel,String(b.mat||'').trim(),fi,b.role]);
if(!r.rows[0])return bad(res,409,'Este e-mail já está cadastrado. Use "Entrar".');
login(req,res,r.rows[0].id);res.json({ok:1})}catch(e)
{console.error(e);bad(res,500,'Erro no servidor.')}});
app.post('/api/login',async(req,res)=>{try{const b=req.body||{},r=await
db.query('select id,hash from users where email=$1',
[String(b.email||'').trim().toLowerCase()]);
if(!r.rows[0]||!check(String(b.senha||''),r.rows[0].hash))return bad(res,401,'E-mail
ou senha incorretos.');login(req,res,r.rows[0].id);res.json({ok:1})}catch(e)
{console.error(e);bad(res,500,'Erro no servidor.')}});
app.post('/api/logout',(req,res)=>{cookie(req,res,'',0);res.json({ok:1})});
app.get('/api/me',auth,(req,res)=>res.json(req.u));
app.get('/api/c/:c/:id?',auth,async(req,res)=>{try{const{c,id}=req.params,u=req.u;
if(c==='profiles'){const r=isM(u)?(await db.query('select
id,email,nome,tel,mat,fi,role from users order by id')).rows:[u];return
res.json(r.filter(x=>!id||String(x.id)===id).map(x=>({id:String(x.id),data:
{uid:String(x.id),nome:x.nome,email:x.email,tel:x.tel,mat:x.mat,fi:x.fi,role:x.role}}
)))}
if(c==='approvals')return res.json([]);
if(!COLL.includes(c))return res.json([]);
const p=[c];let q='select id,data from docs where coll=$1';if(id){p.push(id);q+=' and
id=$2'}
p.push(fil(u.fi));q+=scope(u,c,'$'+p.length);if(isM(u)||c==='config')p.pop();
res.json((await db.query(q,p)).rows)}catch(e)
{console.error(e);res.status(500).json([])}});
async function allowed(u,c,id){if(isM(u)||c==='config')return true;const a=await
db.query('select 1 from docs where coll=$1 and id=$2',[c,id]);if(!a.rows[0])return
true;return !!(await db.query('select 1 from docs where coll=$1 and
id=$2'+scope(u,c,'$3'),[c,id,fil(u.fi)])).rows[0]}
app.put('/api/c/:c/:id',auth,async(req,res)=>
{try{const{c,id}=req.params,u=req.u,d=req.body;
if(c==='profiles'||c==='approvals')return res.json({ok:1});
if(!COLL.includes(c))return bad(res,404,'Coleção inválida.');
if(c==='config'&&!isM(u))return bad(res,403,'Só a matriz altera configurações.');
if(!await allowed(u,c,id))return bad(res,403,'Sem permissão.');
if(c==='sales'&&!isM(u))d.fi=u.fi;
await db.query('insert into docs(coll,id,data) values($1,$2,$3) on conflict(coll,id)
do update set data=excluded.data',[c,id,d]);res.json({ok:1})}catch(e)
{console.error(e);bad(res,500,'Erro no servidor.')}});
app.delete('/api/c/:c/:id',auth,async(req,res)=>{try{const{c,id}=req.params,u=req.u;
if(!COLL.includes(c))return res.json({ok:1});
if(c==='config'&&!isM(u))return bad(res,403,'Só a matriz altera configurações.');
if(!await allowed(u,c,id))return bad(res,403,'Sem permissão.');
await db.query('delete from docs where coll=$1 and id=$2',
```

```
[c,id]);res.json({ok:1})}catch(e){console.error(e);bad(res,500,'Erro no servidor.')}});
app.get('/',(q,s)=>s.type('html').send(fs.readFileSync(__dirname+'/index.html')));
app.get('/api-shim.js',(q,s)=>s.type('js').send(fs.readFileSync(__dirname+'/api-shim.js')));
const ready=db.query(`create schema if not exists vendas;create table if not exists vendas.users(id serial primary key,email text unique not null,hash text not null,nome text,tel text,mat text,fi text,role text);create table if not exists vendas.docs(coll text,id text,data jsonb,primary key(coll,id))`);ready.catch(e=>console.error(e));
if(require.main===module)app.listen(process.env.PORT||3000,()=>console.log('Servidor no ar'));
module.exports=app;
```